

BÁO CÁO DỰ ÁN CÔNG NGHỆ THÔNG TIN

Nền Tảng Mô Phỏng Truyền Tin Mã Hóa Đầu Cuối (E2EE)
và Phân Tích Mối Đe Dọa An Ninh Mạng

Dự án: Secure Messenger

Đội ngũ phát triển:

Đinh Kỳ Vĩ (Trưởng nhóm)

Nguyễn Ngọc Hồng Đào (Thành viên - UI/UX & Frontend)

Nguyễn Duy Bảo Trân (Thành viên - PoC Developer)

Nguyễn Bùi Minh Hằng (Thành viên - Security Specialist)

Nguyễn Thị Sang, Đặng Hồng Nguyệt

Hoàng Thị Kim Ngân, Nguyễn Thanh Huyền, Nguyễn Phan Thanh Lích

Tháng 7 Năm 2026

Tóm tắt nội dung

Báo cáo này trình bày về thiết kế và triển khai dự án **Secure Messenger** – một ứng dụng mô phỏng hệ thống truyền tin mã hóa đầu cuối (End-to-End Encryption - E2EE) thời gian thực. Dự án được phát triển nhằm mục đích giáo dục, giúp sinh viên và người nghiên cứu an toàn thông tin hiểu sâu hơn về cách thức hoạt động của các giao thức mật mã hiện đại như trao đổi khóa Diffie-Hellman, mã hóa khóa đối xứng AES-256, và cơ chế xoay vòng khóa Double Ratchet. Đồng thời, ứng dụng tích hợp một kịch bản tấn công giả lập thông qua bảng điều khiển của bên thứ ba (Eve) nhằm minh họa trực quan các mối đe dọa từ tấn công XSS (Cross-Site Scripting) và chiếm đoạt tài khoản (Account Takeover). Toàn bộ luồng dữ liệu được đồng bộ hóa thông qua cơ sở dữ liệu Firebase Realtime Database.

Mục lục

1	Giới thiệu chung	3
1.1	Bối cảnh đề tài	3
1.2	Mục tiêu dự án	3
2	Kiến trúc và Cơ chế mật mã cốt lõi	3
2.1	Trao đổi khóa Diffie-Hellman (DH-256)	3
2.2	Cơ chế Double Ratchet	4
2.3	Mã hóa đối xứng AES-256	4
2.4	Kiểm tra tính toàn vẹn SHA-256	4
3	Giao diện người dùng và Trình giám sát kỹ thuật	4
3.1	Thiết kế giao diện ba cột	4
3.2	Bảng giám sát Ratchet Monitor	4
4	Kịch bản phân tích tấn công an ninh mạng	5
4.1	Kịch bản tấn công XSS	5
4.2	Tấn công Phishing và Chiếm đoạt tài khoản	5
5	Công nghệ và Phân chia vai trò	5
5.1	Công nghệ sử dụng	5
5.2	Phân chia vai trò thành viên	5
6	Kết luận và Định hướng tương lai	6
6.1	Kết quả đạt được	6
6.2	Định hướng phát triển	6

1 Giới thiệu chung

1.1 Bối cảnh đề tài

Trong thời đại kỹ thuật số, bảo mật thông tin liên lạc là một trong những yếu tố sống còn đối với cá nhân lẫn tổ chức. Mã hóa đầu cuối (End-to-End Encryption - E2EE) đã trở thành tiêu chuẩn vàng cho các ứng dụng nhắn tin phổ biến như Signal, WhatsApp, hay Telegram. Tuy nhiên, đối với phần lớn người dùng và sinh viên công nghệ, các khái niệm toán học và luồng xử lý kỹ thuật bên dưới E2EE vẫn còn mang tính trừu tượng.

1.2 Mục tiêu dự án

Dự án **Secure Messenger** được xây dựng nhằm giải quyết các mục tiêu chính sau:

- Trực quan hóa các khái niệm toán học phức tạp của mật mã học (như Diffie-Hellman, Double Ratchet) thành các biểu đồ và số liệu cập nhật thời gian thực.
- Cung cấp môi trường kiểm thử (sandbox) an toàn để trải nghiệm kịch bản tấn công an ninh mạng thực tế.
- Tạo ra một ứng dụng Web hoàn chỉnh sử dụng công nghệ Frontend thuần vô cùng mượt mà kết hợp đồng bộ hóa dữ liệu thông qua Cloud Database (Firebase).

2 Kiến trúc và Cơ chế mật mã cốt lõi

Hệ thống mật mã của Secure Messenger hoạt động dựa trên sự kết hợp chặt chẽ giữa các giải thuật trao đổi khóa bất đối xứng và mã hóa đối xứng.

2.1 Trao đổi khóa Diffie-Hellman (DH-256)

Thuật toán Diffie-Hellman cho phép hai bên thiết lập một khóa bí mật chung qua kênh truyền thông không an toàn mà không cần biết khóa của nhau trước đó. Các tham số mặc định được sử dụng trong hệ thống mô phỏng là số nguyên tố lớn $P = 23$ và căn nguyên thủy $G = 5$.

1. Alice chọn một số nguyên ngẫu nhiên làm khóa riêng tư X_A (ví dụ: $X_A = 6$) và tính khóa công khai của mình:

$$Y_A = G^{X_A} \pmod{P} = 5^6 \pmod{23} = 8 \quad (1)$$

2. Bob chọn một số riêng tư X_B (ví dụ: $X_B = 15$) và tính khóa công khai:

$$Y_B = G^{X_B} \pmod{P} = 5^{15} \pmod{23} = 19 \quad (2)$$

3. Khóa bí mật dùng chung (Shared Secret Key) K được hai bên tính độc lập:

$$K = Y_B^{X_A} \pmod{P} = 19^6 \pmod{23} = 2 \quad (3)$$

$$K = Y_A^{X_B} \pmod{P} = 8^{15} \pmod{23} = 2 \quad (4)$$

Khóa K này sau đó được sử dụng làm đầu vào cho thuật toán mã hóa đối xứng.

2.2 Cơ chế Double Ratchet

Mô phỏng giao thức Double Ratchet (tương tự như trong Signal Protocol), hệ thống tự động xoay vòng khóa bí mật sau mỗi lượt gửi và nhận tin nhắn. Điều này đảm bảo tính bảo mật chuyển tiếp hoàn hảo (Perfect Forward Secrecy) – nghĩa là nếu tin tặc chiếm đoạt được một khóa phiên hiện tại, họ cũng không thể giải mã các tin nhắn cũ hơn hoặc các tin nhắn tiếp theo trong tương lai.

2.3 Mã hóa đối xứng AES-256

Khi khóa bí mật dùng chung được tạo ra hoặc xoay vòng, nội dung tin nhắn sẽ được mã hóa bằng thuật toán AES-256 (Advanced Encryption Standard) với chế độ CBC (Cipher Block Chaining) và phần đệm PKCS7 thông qua thư viện **CryptoJS**. Vector khởi tạo (IV) được cố định hoặc đồng bộ để đảm bảo quá trình giải mã chính xác ở đầu nhận.

2.4 Kiểm tra tính toàn vẹn SHA-256

Để ngăn chặn các cuộc tấn công thay đổi thông điệp trên đường truyền (Man-in-the-Middle), hệ thống tính toán mã băm SHA-256 của bản mã trước khi gửi đi:

$$\text{Hash} = \text{SHA256}(\text{Ciphertext}) \quad (5)$$

Dầu nhận sau khi lấy dữ liệu sẽ băm lại bản mã và so sánh với mã băm nhận được. Nếu khớp, tin nhắn được xác nhận toàn vẹn và tiến hành giải mã; nếu không khớp, hệ thống sẽ cảnh báo dữ liệu bị can thiệp.

3 Giao diện người dùng và Trình giám sát kỹ thuật

3.1 Thiết kế giao diện ba cột

Giao diện của Secure Messenger được thiết kế trực quan bằng Vanilla CSS, tối ưu hóa không gian hiển thị song song:

- **Cột trái (Alice's View):** Giao diện gửi và nhận tin nhắn dưới vai trò Alice.
- **Cột giữa (Ratchet Monitor):** Hiển thị trực quan quá trình sinh khóa, giá trị khóa phiên, mã băm SHA-256 và sơ đồ luồng truyền tin.
- **Cột phải (Bob's View):** Giao diện gửi và nhận tin nhắn dưới vai trò Bob.

3.2 Bảng giám sát Ratchet Monitor

Bảng giám sát cung cấp phản hồi hình ảnh tức thời (real-time feedback) khi người dùng thao tác. Các thông số mật mã học thay đổi liên tục, làm nổi bật trạng thái hoạt động của thuật toán dưới dạng các chip dữ liệu phát sáng mang phong cách công nghệ (cyberpunk/glassmorphism).

4 Kịch bản phân tích tấn công an ninh mạng

Hệ thống tích hợp bảng điều khiển an ninh mạng chuyên biệt (**Hacker Console**) của nhân vật bên thứ ba mang tên Eve.

4.1 Kịch bản tấn công XSS

Kịch bản mô phỏng cuộc tấn công Cross-Site Scripting diễn ra theo các bước sau:

1. **Gửi liên kết độc hại:** Eve gửi tin nhắn chứa đường dẫn phishing đến Alice.
2. **Kích hoạt XSS:** Alice nhấn vào liên kết, kích hoạt mã độc tiêm vào DOM.
3. **Chiếm quyền kiểm soát (Fake Remote Cursor):** Giao diện Alice bị làm tối, xuất hiện hiệu ứng con trỏ chuột giả đang tự động di chuyển nhằm minh họa việc máy tính bị chiếm quyền điều khiển từ xa.

4.2 Tấn công Phishing và Chiếm đoạt tài khoản

Sau khi kích hoạt XSS, hệ thống sẽ hiển thị một hộp thoại đăng nhập giả mạo (*Fake Login Modal*) yêu cầu Alice nhập mật khẩu vì lí do bảo mật. Khi Alice nhập thông tin:

- Mã độc gửi mật khẩu về Hacker Console của Eve.
- Thiết bị đầu cuối của Eve (hiển thị hiệu ứng chữ xanh phong cách ma trận) ghi nhận thông tin đăng nhập thành công và thông báo chiếm đoạt tài khoản hoàn tất (*Account Takeover Success*).

—

5 Công nghệ và Phân chia vai trò

5.1 Công nghệ sử dụng

Dự án được xây dựng trên nền tảng Web tiêu chuẩn không sử dụng các framework nặng nề để đảm bảo tốc độ tải tối đa:

- **Frontend:** HTML5, CSS3, JavaScript ES Modules.
- **Mật mã học:** CryptoJS v4.1.1.
- **Tương tác:** Driver.js (thư viện tạo hướng dẫn tương tác cho người dùng mới).
- **Backend/Database:** Firebase Realtime Database.

5.2 Phân chia vai trò thành viên

—

Bảng 1: Bảng phân chia nhiệm vụ trong dự án

Thành viên	Vai trò chính	Chi tiết đóng góp
Đinh Kỳ Vĩ	Trưởng nhóm	Thuật toán mật mã cốt lõi, kiến trúc E2EE
Nguyễn Ngọc Hồng Đào	UI/UX & Frontend	Thiết kế giao diện, hiệu ứng chuyển cảnh, đa ngôn ngữ
Nguyễn Duy Bảo Trân	PoC & System Integrator	Mô phỏng Java PoC, tích hợp Firebase
Nguyễn Bùi Minh Hằng	Security Analyst	Thiết kế kịch bản tấn công XSS và Hacker Console
Nhóm hỗ trợ	Kiểm thử & Tài liệu	Đóng góp dữ liệu thử nghiệm, slide báo cáo

6 Kết luận và Định hướng tương lai

6.1 Kết quả đạt được

Ứng dụng **Secure Messenger** đã hoàn thành xuất sắc mục tiêu mô phỏng một cách trực quan, sinh động luồng xử lý mã hóa đầu cuối phức tạp và minh họa thành công mức độ nguy hiểm của các lỗ hổng bảo mật thông qua kịch bản XSS thực tế. Dự án nhận được đánh giá cao nhờ sự mượt mà trong giao diện và tính tương tác cao.

6.2 Định hướng phát triển

Trong tương lai, nhóm phát triển định hướng nâng cấp hệ thống với các tính năng:

- Hỗ trợ cấu hình tùy biến độ dài khóa mật mã (DH-512 hoặc DH-1024).
- Tích hợp thêm các kịch bản tấn công mạng nâng cao như tấn công trung gian (Man-in-the-Middle) và phân tích tần suất mã hóa cổ điển.
- Nghiên cứu ứng dụng chuẩn WebRTC để truyền tin trực tiếp ngang hàng (Peer-to-Peer) thực sự.

Tài liệu

- [1] W. Diffie and M. Hellman, “New directions in cryptography,” in *IEEE Transactions on Information Theory*, vol. 22, no. 6, pp. 644-654, November 1976.
- [2] National Institute of Standards and Technology (NIST), “FIPS PUB 197: Advanced Encryption Standard (AES),” November 2001.
- [3] T. Perrin and D. Whisper Systems, “The Double Ratchet Algorithm,” 2016. [Online]. Available: <https://signal.org/docs/specifications/doubleratchet/>